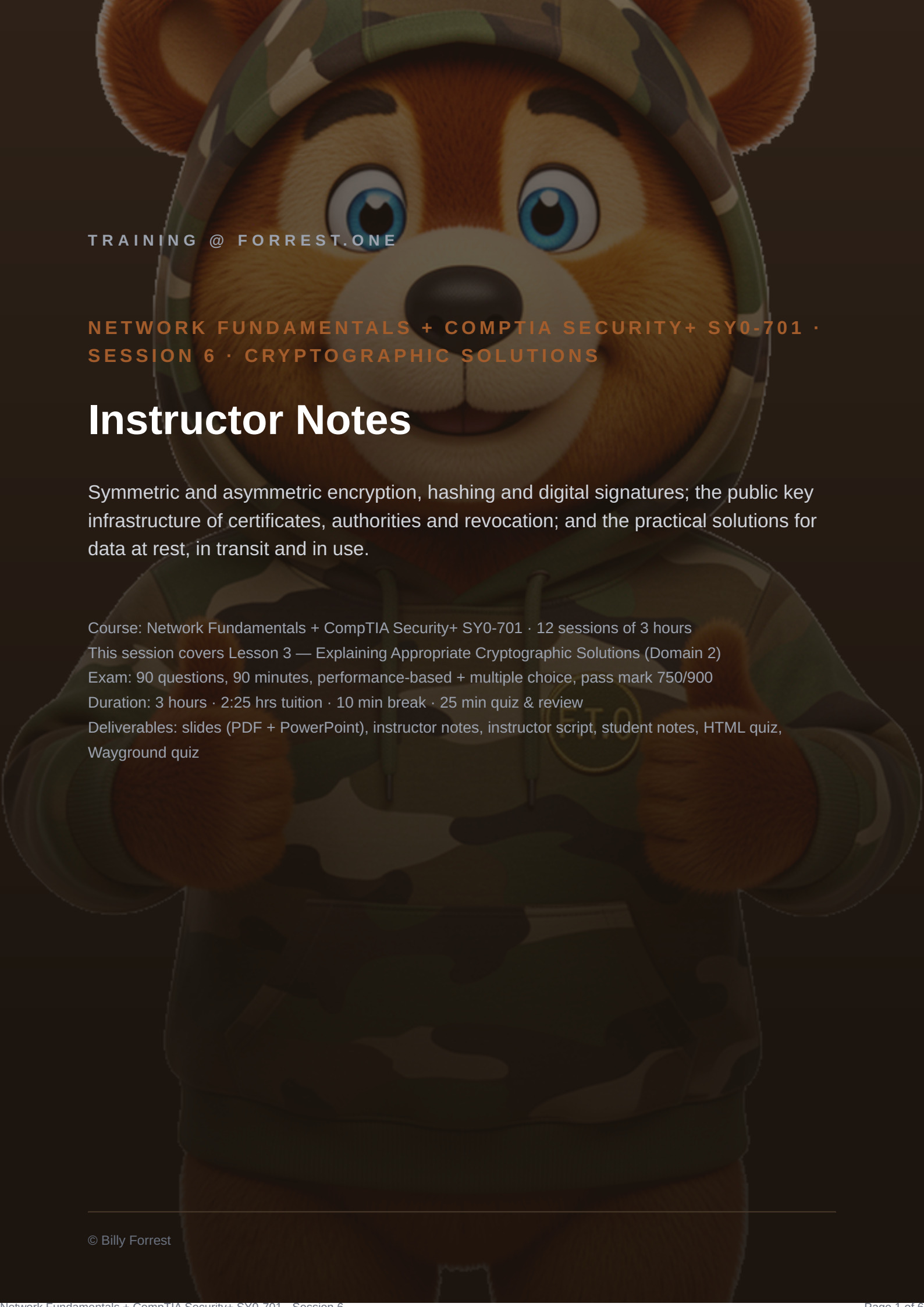




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 6 · CRYPTOGRAPHIC SOLUTIONS

Instructor Notes

Symmetric and asymmetric encryption, hashing and digital signatures; the public key infrastructure of certificates, authorities and revocation; and the practical solutions for data at rest, in transit and in use.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 3 — Explaining Appropriate Cryptographic Solutions (Domain 2)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Notes — Cryptography & Public Key Infrastructure

A 3-hour delivery guide for Session 6. The session is now in five chapters: the three jobs and the security vocabulary, integrity and trust, cryptographic applications and the paper trail, identity and access management, and controlling access. Cryptography is a frequent exam area and a common source of confusion, so keep the emphasis on job-fit: which tool for which job, rather than algorithm internals. The reference material reinforces this by naming the standard algorithms, AES, RSA and ECC, and their roles, so drive those roles home. The activities reinforce job-fit and give you a check on the room.

Exam angle: Domain 2 (Threats, Vulnerabilities and Mitigations) rewards scenario questions that ask which algorithm, which certificate mechanism or which data-state control fits a situation. Candidates who learn the three-job map (encrypt, hash, sign), the state map (at rest, in transit, in use) and the identity split (authentication proves who you are, authorisation decides what you may do) can answer most items without any mathematics. Chapters four and five also support the identity and access objectives, so expect questions that mix a cryptographic control with an access decision.

Session at a glance

Time	Block	Slides	Focus / activity
0:00–0:15	Welcome and the vocabulary	1–4	CIA triad; vulnerability, threat, exploit, risk; session objectives
0:15–0:55	Algorithms, hashing and signatures	5–12	Symmetric, key length, asymmetric, TLS, hashing, signatures; activity
0:55–1:25	Public key infrastructure	13–19	CAs, certificates, root and chain of trust, CSR, revocation, key management; discussion
1:25–1:35	Break	20	10-minute break
1:35–2:05	Cryptographic solutions and applications	21–32	Data states, disk and database encryption, PFS, salting; blockchain, obfuscation, documentation; activity
2:05–2:35	Identity and access	33–44	Authentication and authorisation, roles, factors, MFA, SSO, federation, RADIUS, TACACS+, LDAP, access control models
2:35–3:00	Quiz and close	45–49	Takeaways; Quiz_Session_06.html; exam alignment; revision checklist; preview

Materials and preparation

- Projector or screen with the Session 6 slide deck (02_Slides.pdf or 02_Slides.pptx).
- One computer or tablet per pair for Quiz_Session_06.html.
- Printed or digital copy of the Student Notes for each candidate.
- Whiteboard or flipchart for the which-tool activity and the factor-sorting activity.
- A browser certificate viewer for the certificate-inspection homework (optional).
- Optional: a phone with an authenticator app, to demonstrate a time-based one-time password.

Delivery guidance by slide

Slides 1–4 · Welcome and the vocabulary (15 minutes)

Open with the three jobs. Confidentiality, integrity and availability are the organising idea of the whole session, so ask the room which of the three a stolen laptop threatens, and which a tampered invoice threatens. Then fix the vocabulary: a vulnerability is a weakness, a threat is anything that could exploit it, an exploit is the method, and risk combines likelihood with impact. Candidates lose marks by using these words loosely, so make them say the sentences aloud. Close with the objectives, which now include the identity and access material in chapters four and five.

Slides 5–12 · Algorithms, hashing and signatures (40 minutes)

Symmetric: one key, fast, distribution problem; introduce AES with its three key sizes. Slide 6 covers keyspace and brute force, and it is worth saying that each added bit doubles the attacker's work. Asymmetric: pairs, which solve distribution, and slower; introduce RSA and the idea that elliptic curve cryptography reaches similar strength with smaller keys, which matters on mobile and constrained devices. Slide 8 shows how TLS uses both, and it sets up the later data-state material, so make the handshake-to-session-key sequence explicit. Hashing: one-way, integrity; teach the avalanche effect and the status table, which is a direct exam item. Signatures: hash plus private key, verified with the public key, giving integrity, authentication and non-repudiation. Slide 12's activity forces job-fit decisions, which is the exam skill.

Activity (slide 12)

Which tool for which job: bulk backup (symmetric), contract integrity (hashing), sender authentication (a digital signature), key exchange (asymmetric). 8 minutes in pairs; debrief on the three-job map. Ask each pair to defend its choice in one sentence.

Slides 13–19 · Public key infrastructure (30 minutes)

Certificates bind public keys to identities; the chain of trust provides the root of trust. Add the registration authority as the verification intermediary. Slide 14 covers what a certificate actually carries and the CN versus SAN distinction, which is a favourite exam contrast. Slide 16 walks the CSR flow and repeats the rule that the private key never travels. Slide 17 contrasts CRL with OCSP, and slide 18 gives you TPM, HSM and escrow with M-of-N control. The discussion on slide 19 corrects the certificate-equals-safe-site myth, and it is the single most useful correction in the session.

Exam angle (slide 17)

CRL is a periodically published list that clients download; OCSP is a real-time query about one certificate. Ask when each is preferred: OCSP gives a fresh status without pulling a whole list. Then ask why a revoked certificate must stop being trusted quickly, because a compromised key could otherwise keep signing or decrypting.

Slides 21–32 · Solutions, applications and the paper trail (30 minutes)

Organise the solutions block by data state: at rest (disk, file and database), in transit (TLS and perfect forward secrecy), in use. Perfect forward secrecy is the examinable property here, so state it plainly: ephemeral session keys mean a later key compromise cannot decrypt past traffic. Salting and stretching are password-storage essentials. Then move to the applications chapter, which the exam tests with scenarios rather than definitions. For each technique, ask what problem it solves: tokenisation for card data, masking for test environments, obfuscation against reverse engineering, steganography to hide existence, blockchain for a tamper-evident shared record. Documentation and version control close the chapter, and they matter more than they sound: knowing what changed, and when, is half of security. The activity on slide 32 consolidates state-first, tool-second thinking.

Exam angle (slide 25)

Salting defeats pre-computed tables because every salted hash is unique; key stretching raises the cost of every guess. The exam tests the pairing: salt plus stretch together, never plain password storage. Ask candidates to explain the difference between encrypting a stored password and hashing it, because that confusion recurs.

Slides 33–44 · Identity and access (30 minutes)

Start with the distinction that carries the whole chapter: authentication proves who you are, authorisation decides what you may do, and a user can be authenticated and still be denied. Then roles and the identity lifecycle, where deprovisioning is the step organisations get wrong. The three factors follow, and the important teaching point is that multi-factor means two or more different families, so a password plus a personal identification number is still single factor. Move to one-time passwords, the phishing caveat and passwordless designs, then single sign-on with SAML's two roles, then federation and its widened blast radius. Chapter five finishes with RADIUS, TACACS+, directories and access control models. Keep asking which protocol answers the same question in a different way.

Discussion prompt (slides 35–37)

Ask the room to sort six authentication methods into the three factors, then challenge two of them: a password plus a personal identification number (one factor), and a code sent by SMS (something you have, but relayable by phishing). Then ask what one login buys you, and what it costs when it is compromised.

Exam angle (slide 40)

The RADIUS and TACACS+ contrast is a direct exam item: UDP versus TCP, combined functions versus separated functions, coarse versus command-level authorisation. Give the memory hook plainly: RADIUS for network access, TACACS+ for managing the devices. For LDAP, remember 389 in the clear, LDAPS on 636, and StartTLS to upgrade an existing connection.

Slides 45–49 · Quiz and close (25 minutes)

Walk the takeaways, run the quiz and review the low scores by objective, then set the certificate-inspection homework and preview Session 7, which turns to the threat landscape.

Common misconceptions and corrections

Misconception	Correction
Asymmetric is always better	Symmetric is faster for bulk data; asymmetric handles keys and small payloads
Encryption guarantees integrity	Encryption provides confidentiality; hashing provides integrity
A certificate means the site is safe	It proves key-to-identity binding, not legitimacy or safety
MD5 is fine for passwords	MD5 and SHA-1 are broken; use SHA-256 or better, with salt and stretching
Key escrow is insecure	Escrow is controlled backup, and M-of-N control splits the risk
Tokenisation is encryption	Tokens are substitutes, reversible only through the token store
CRL and OCSP are the same	CRL is a published list; OCSP is a real-time per-certificate query
ECC is weaker than RSA	ECC reaches comparable strength with smaller keys, which suits constrained devices
Authentication and authorisation are the same thing	Authentication proves identity; authorisation decides what that identity may do
A password plus a PIN is multi-factor	Both are something you know, so it is still single factor
One-time passwords cannot be phished	A code can be relayed in real time; a hardware key resists that
Single sign-on is risk-free convenience	One login is one point of failure, so protect sessions, tokens and MFA at the provider
Steganography and encryption do the same job	Encryption hides meaning; steganography hides existence
RADIUS and TACACS+ are interchangeable	RADIUS is for network access; TACACS+ gives command-level control over devices
A directory is a general-purpose database	It is built for reading and searching, and writing is deliberately uncommon

Exam alignment check

- All session objectives map to the cryptography objectives of Domain 2 and the identity and access objectives of Domain 4.
- Quiz tags map every question to its exam objective for traceable revision.
- No mathematical depth is required: the session stays at job-fit level.
- Recognise the named algorithms by role: AES for symmetric bulk work, RSA and ECC for asymmetric and key exchange.
- Use the data-state map for scenario questions: at rest → disk, file and database; in transit → TLS and PFS; in use → memory controls.
- Keep the identity split ready for scenario questions: who you are versus what you may do.
- Know the protocol pairs the exam loves: CRL versus OCSP, TPM versus HSM, RADIUS versus TACACS+, LDAP versus LDAPS, CN versus SAN.